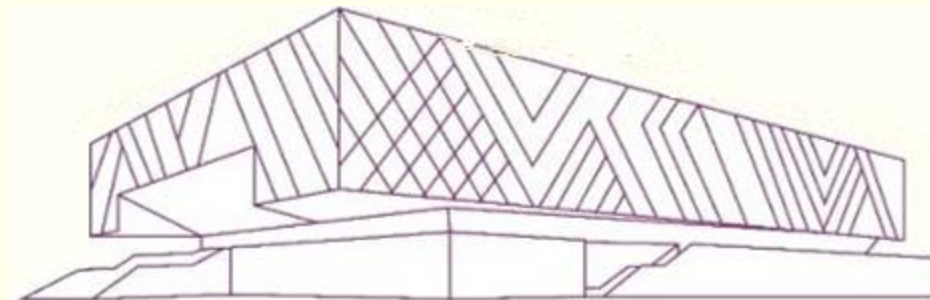




天津工业大学
TIANJIN POLYTECHNIC UNIVERSITY

第七章 IPSec VPN技术

—— 入侵防御与Internet安全协议 ——



目 标

学完本课程后，需要掌握：

- 理解IPSec技术的基本原理
- 理解AH和ESP技术
- 了解IKE协议的业务流程
- 掌握IPSec VPN的应用场景及配置

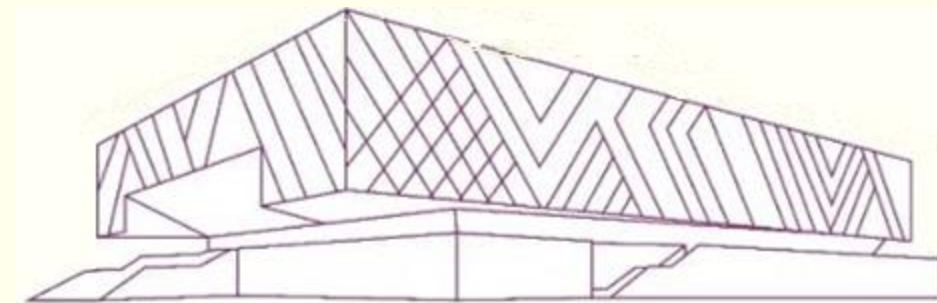
本章目录

- 1 IPSec VPN概述
- 2 IPSec VPN体系结构
- 3 验证头 (AH) 技术
- 4 封装安全载荷 (ESP) 技术
- 5 Internet密钥交换 (IKE) 技术
- 6 IPSec VPN应用场景分析



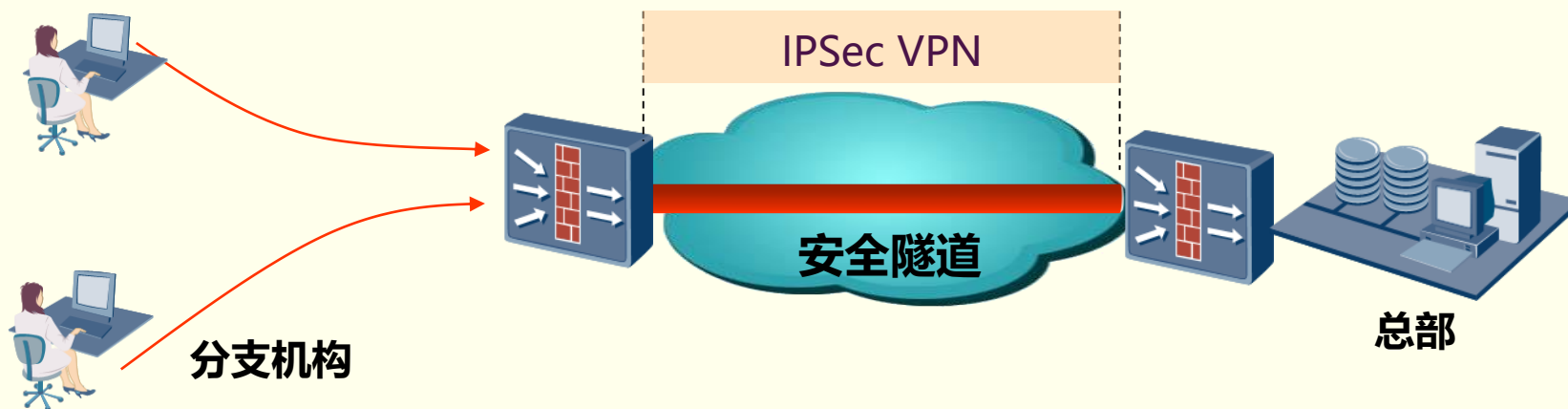
1

IPSec VPN概述

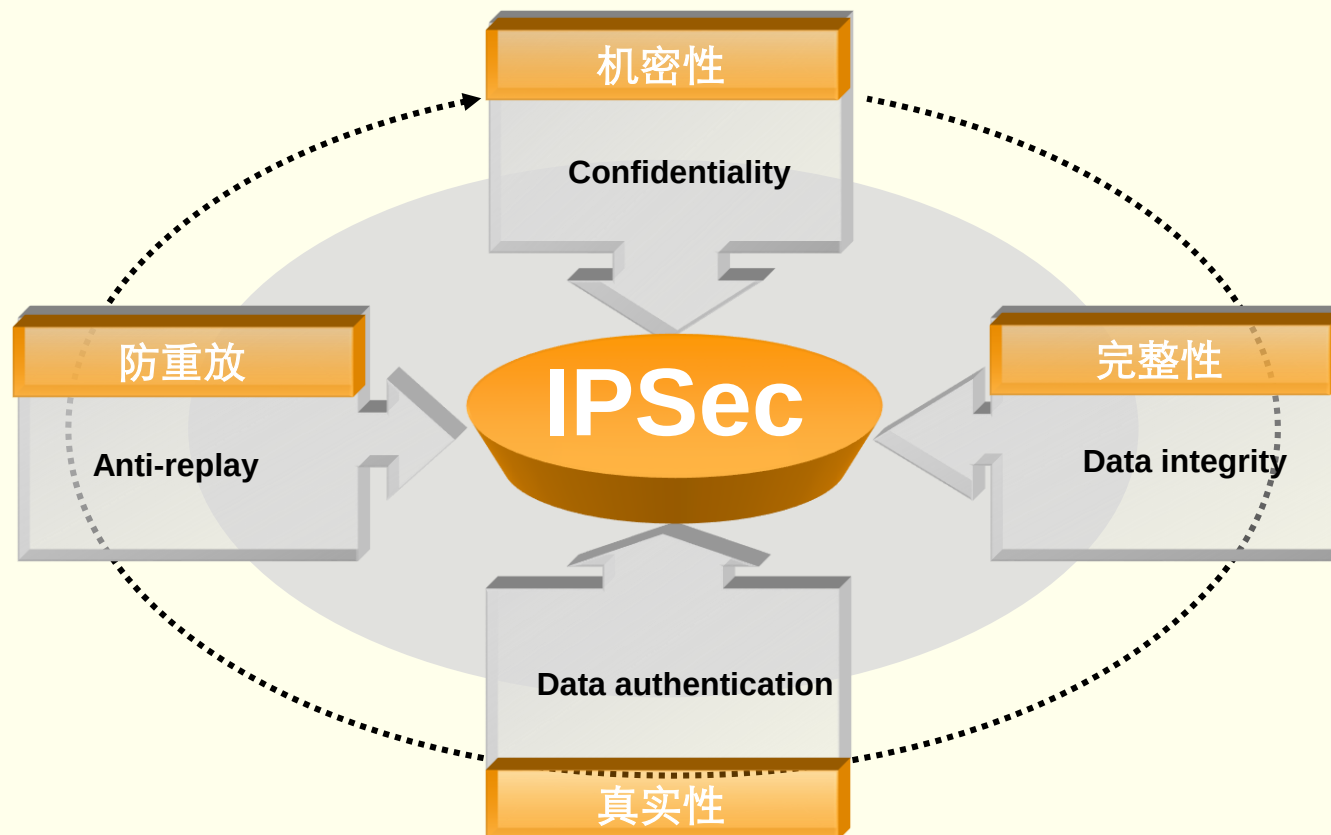


IPSec简介

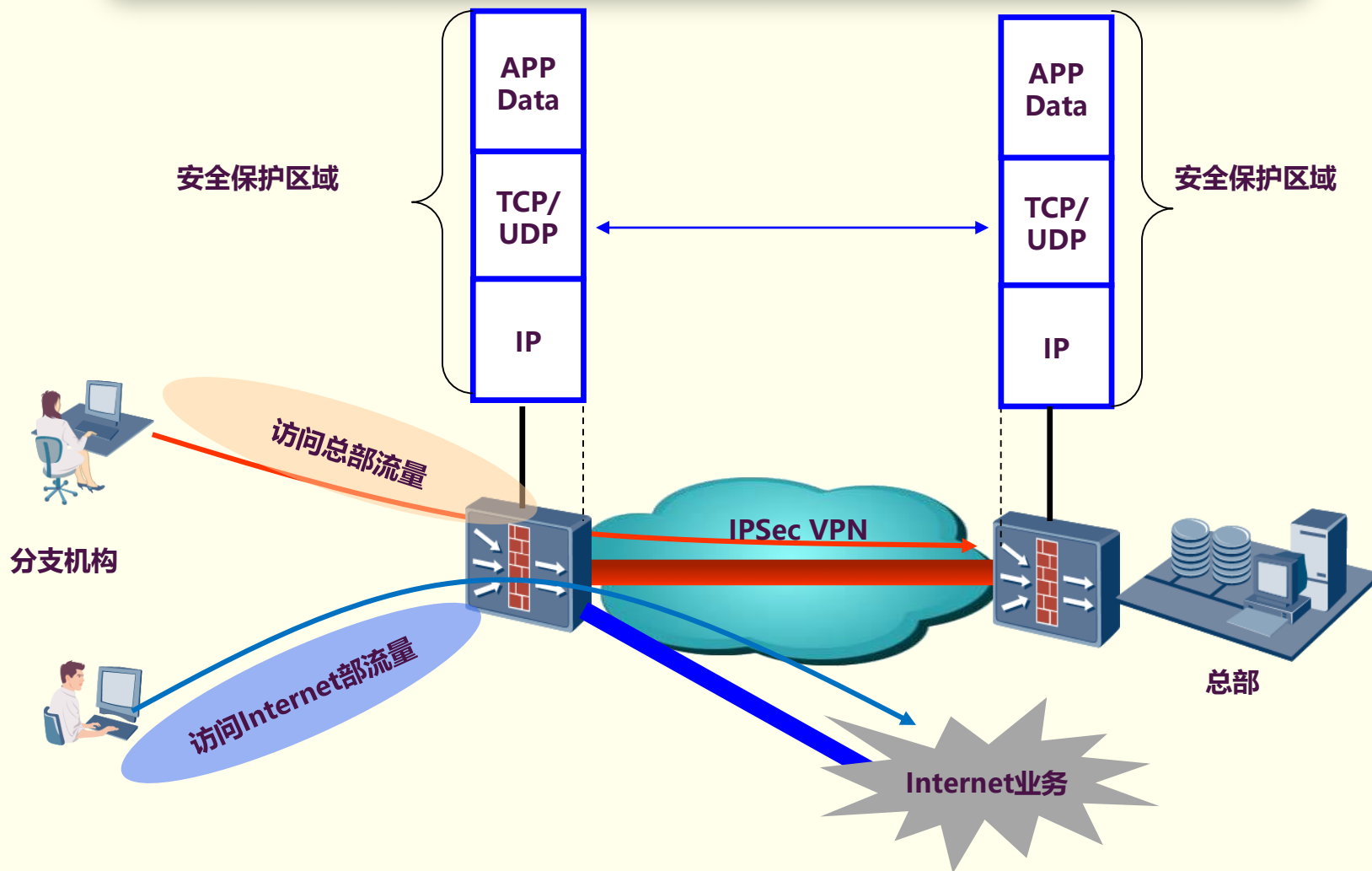
- IPSec (IP Security) 协议族是IETF制定的一系列安全协议，它为端到端IP报文交互提供了基于密码学的、可互操作的、高质量的安全保护机制。IPSec VPN是利用IPSec隧道建立的网络层VPN。



IPSec特性



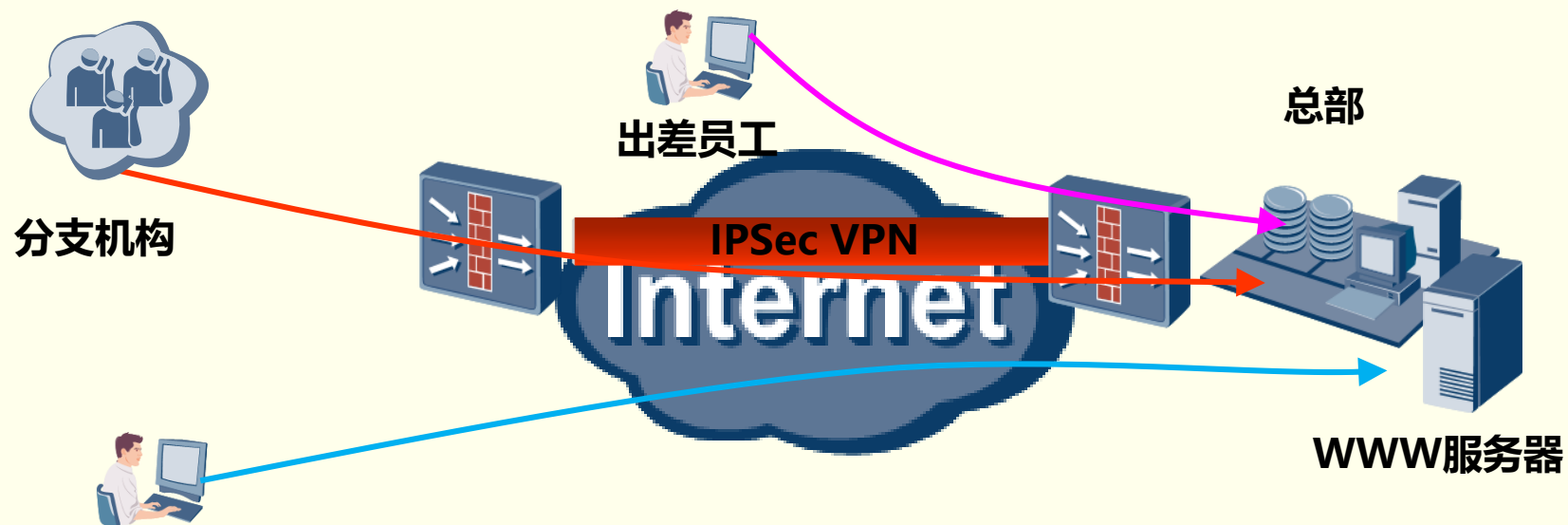
IPSec安全防护特点



IPSec安全防护场景

➤ IPSec端到端应用场景

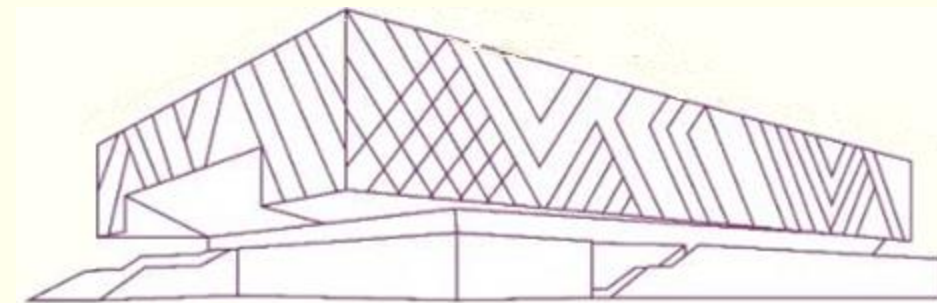
- 安全网关（如防火墙）之间（典型场景）；
- 主机与安全网关之间；
- 主机与主机之间；



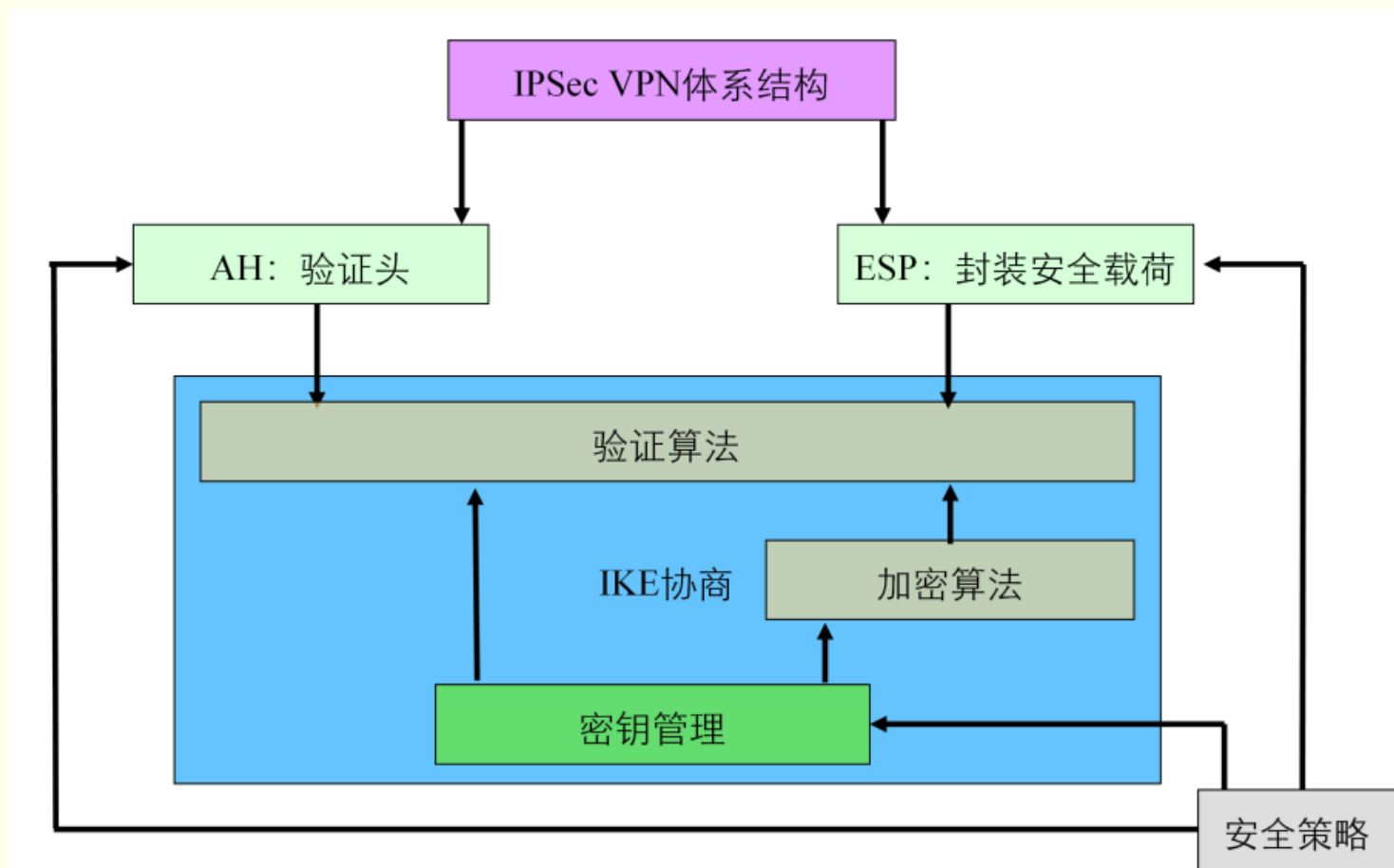


2

IPsec VPN体系结构



IPsec组成部分



IPSec安全协议

- IPSec通过AH (Authentication Header) 和ESP (Encapsulating Security Payload) 这两个安全协议来实现数据报文在网络上传输时的私有性、完整性、真实性和防重放。

AH

- AH (Authentication Header) 报文头验证协议，主要提供的功能有数据源验证、数据完整性校验和防报文重放功能；然而，AH并不加密所保护的数据报文。

ESP

- ESP (Encapsulating Security Payload) ESP是封装安全载荷协议。它除提供AH协议的所有功能外（但其数据完整性校验不包括IP头），还可提供对IP报文的加密功能。

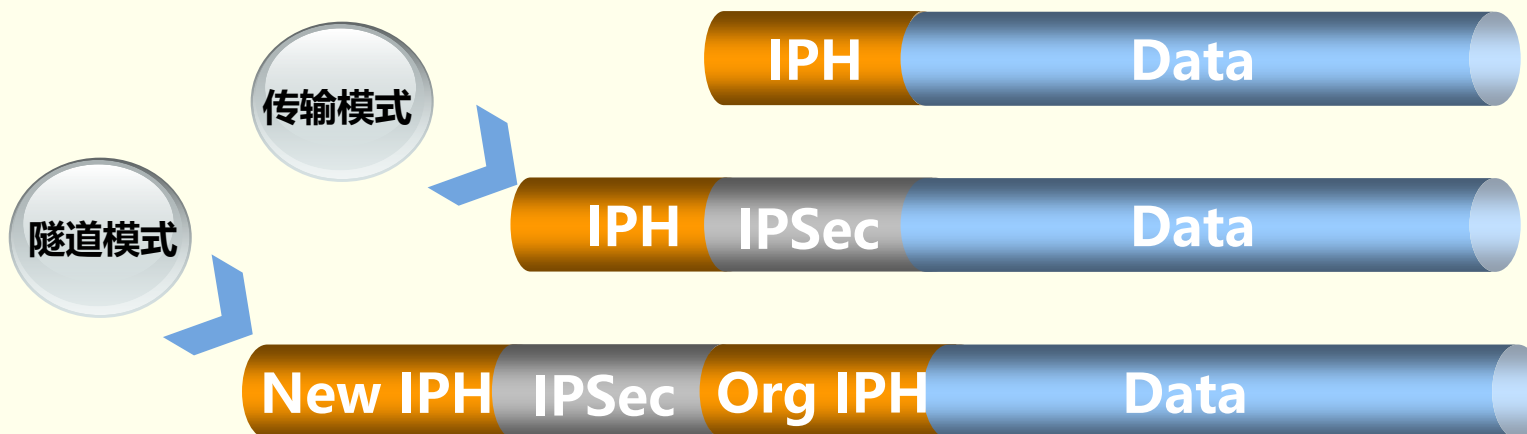
IPSec协议封装模式

传输模式

在传输模式下，IPSec头被插入到IP头之后但在所有传输层协议之前，或所有其他IPSec协议之前。

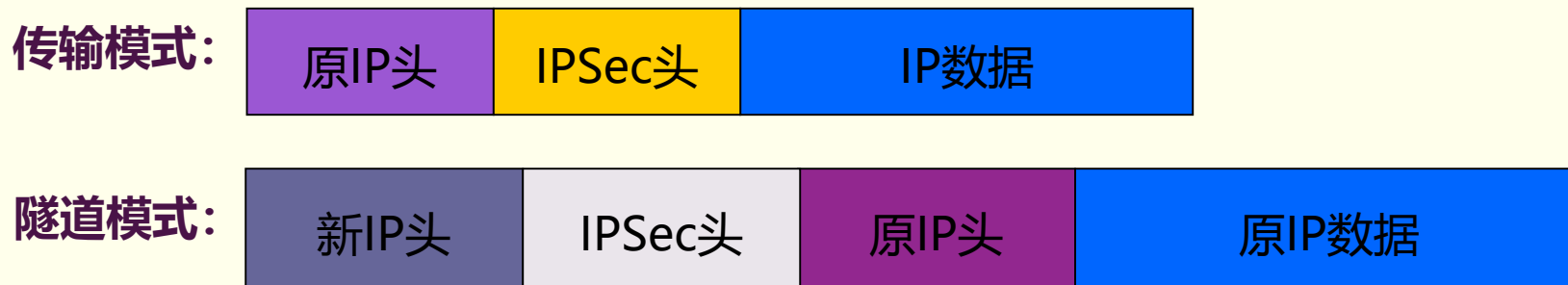
隧道模式

在隧道模式下，IPSec头插在原始IP头之前，另外生成一个新的报文头放到AH或ESP之前。



IPSec协议封装模式对比

- 封装模式对比：
 - 安全性：
 - 隧道模式隐藏原IP头信息，安全性更好。
 - 性能：
 - 隧道模式有一个额外的IP头，隧道模式比传输模式占用更多带宽。
 - 具体选择那种封装模式，需要在性能和安全之间做权衡。



加密和验证算法

- 加密算法

- DES (56bit→64bit)
- 3DES(3个 56bit →64bit)
- AES (128、192、256)
- 国密(256)

- 验证算法

- MD5(128bit)
- SHA-1(160bit)

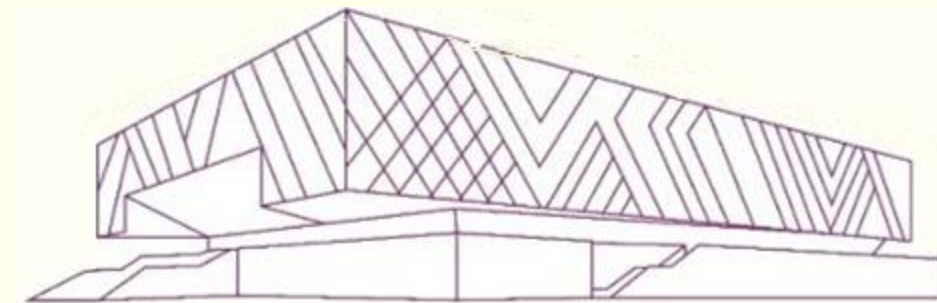


计算复杂度与加密
强度没必然联系



3

验证头 (AH) 技术



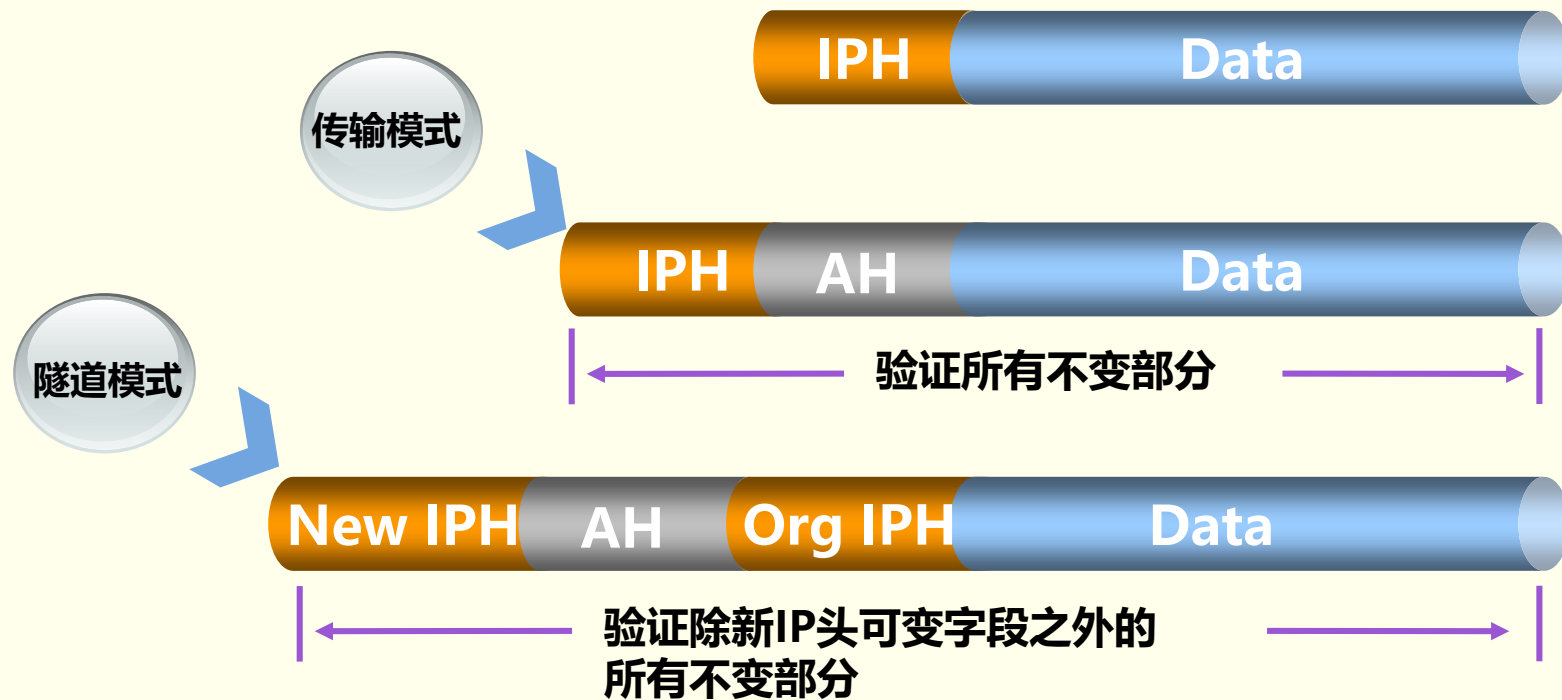
IPSec安全协议-AH

- 提供数据源验证（真实性）、完整性校验和抗重放
- 不支持加密算法



AH报文封装模式

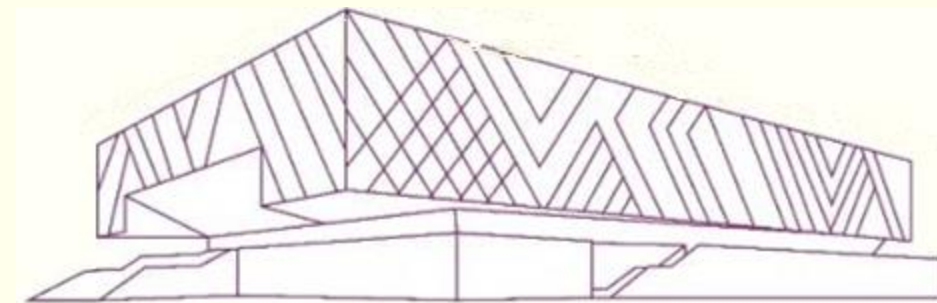
- AH在IP报文头中的协议号为51
 - 传输模式: 验证整个IP报文
 - 隧道模式: 验证新IP头及整个IP报文





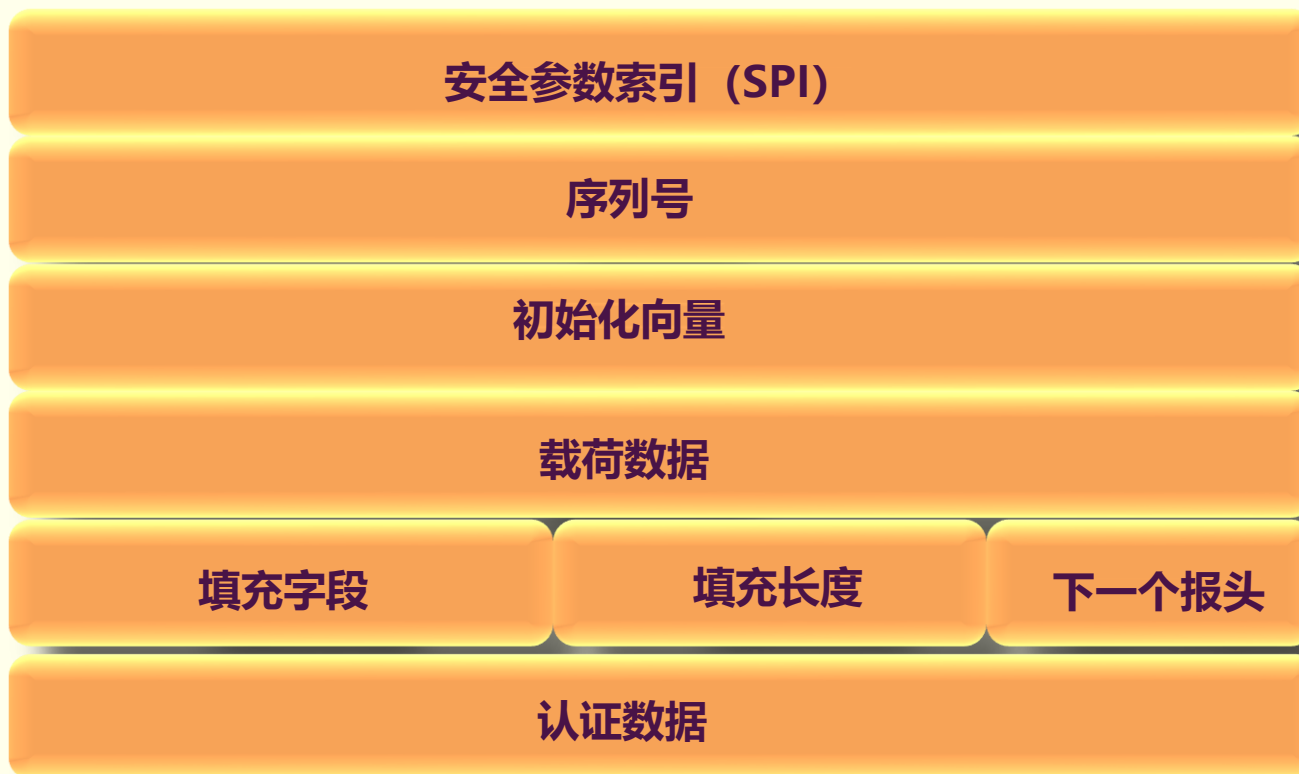
4

封装安全载荷 (ESP) 技术



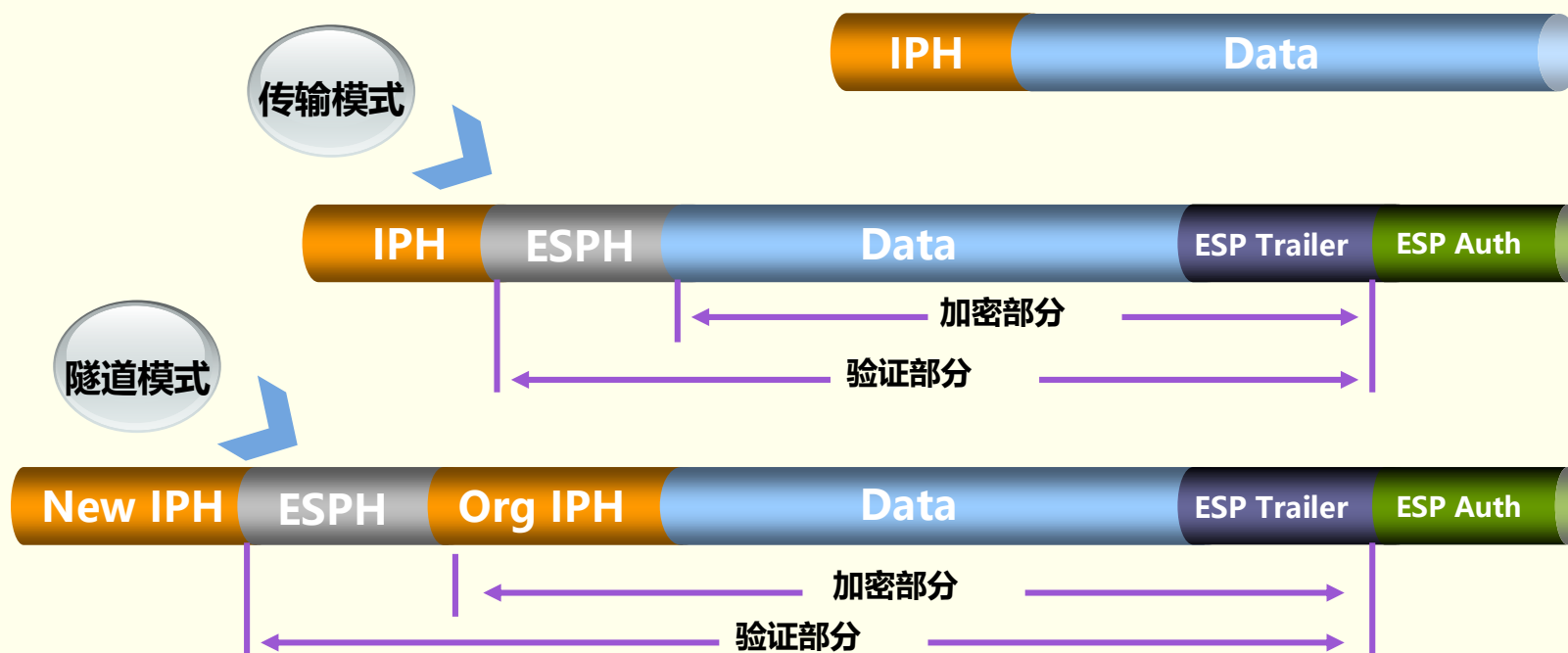
IPSec安全协议-ESP

- 提供数据真实性、数据完整性、抗重放、数据机密性
- 支持加密算法



ESP报文封装模式

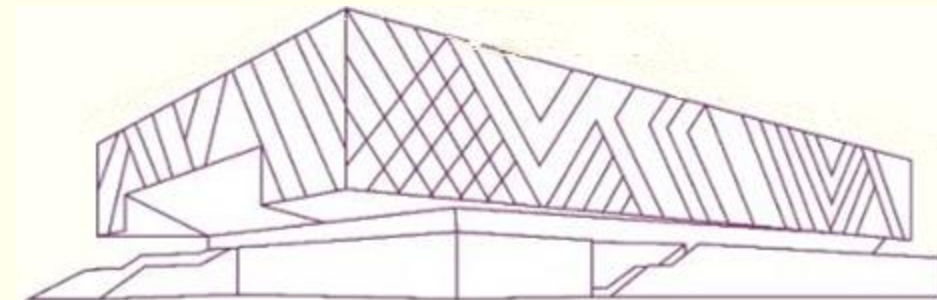
- ESP在IP报头中的协议号为50
 - 传输模式: ESP报头位于IP报头和传输层协议报头之间, 在数据后面增加ESP尾
 - 隧道模式: ESP报头位于新IP头和初始报文之间, 在数据后面增加ESP尾。



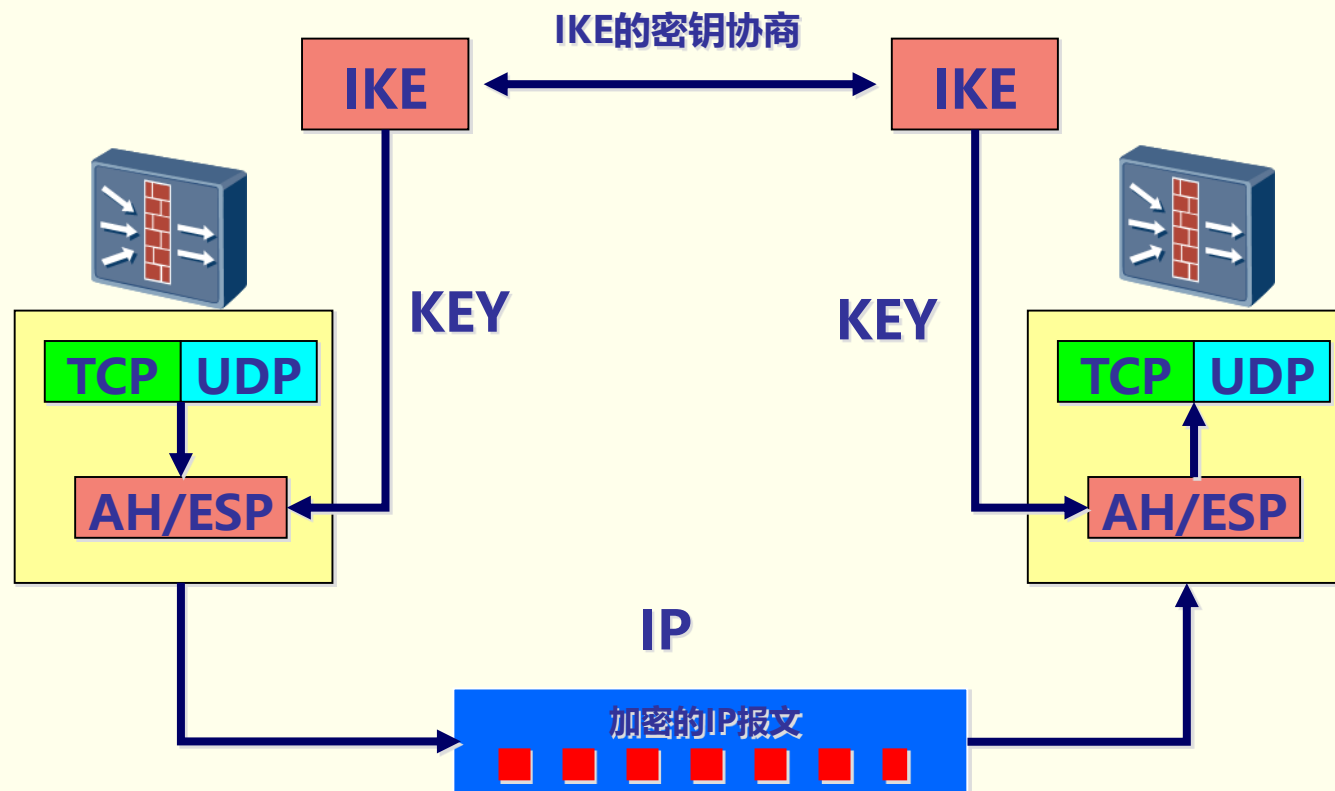


5

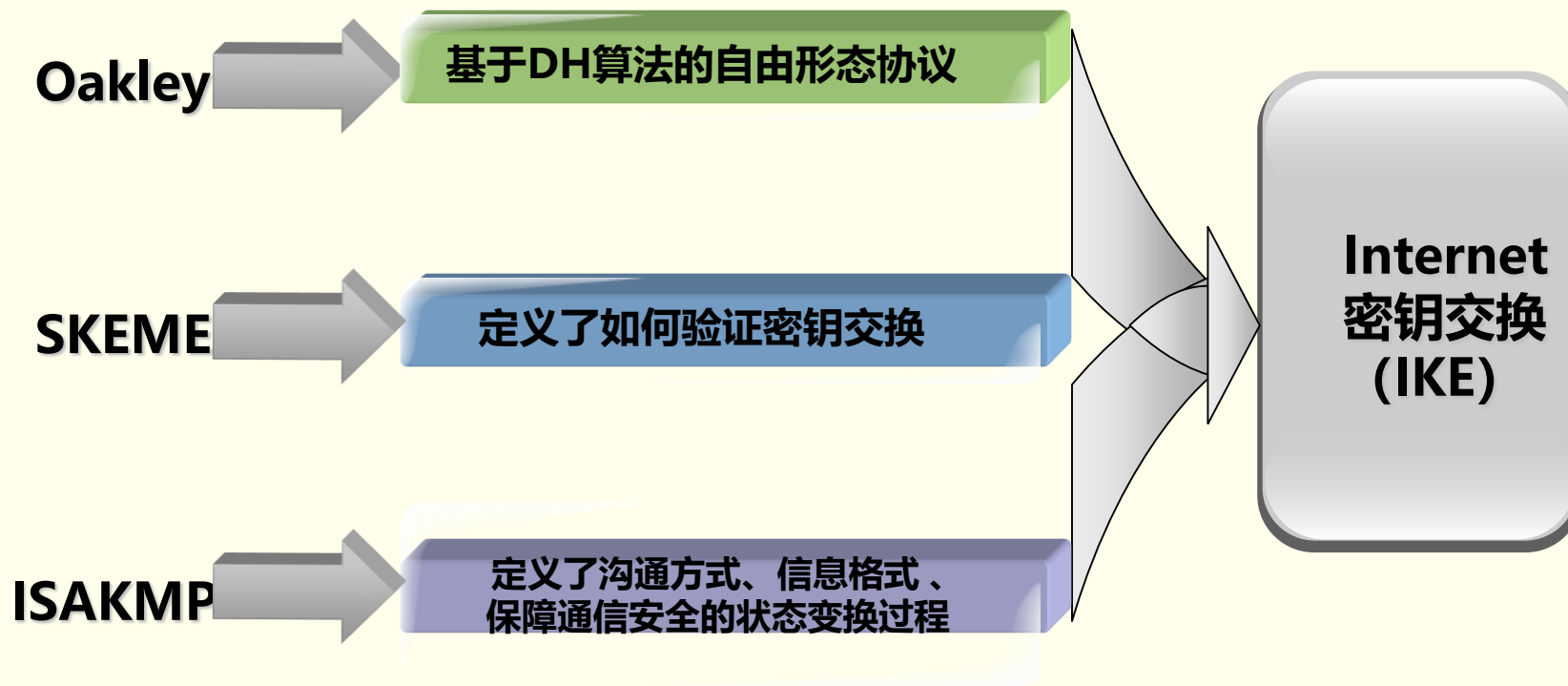
Internet密钥交换 (IKE) 技术



IKE与AH/ESP之间关系

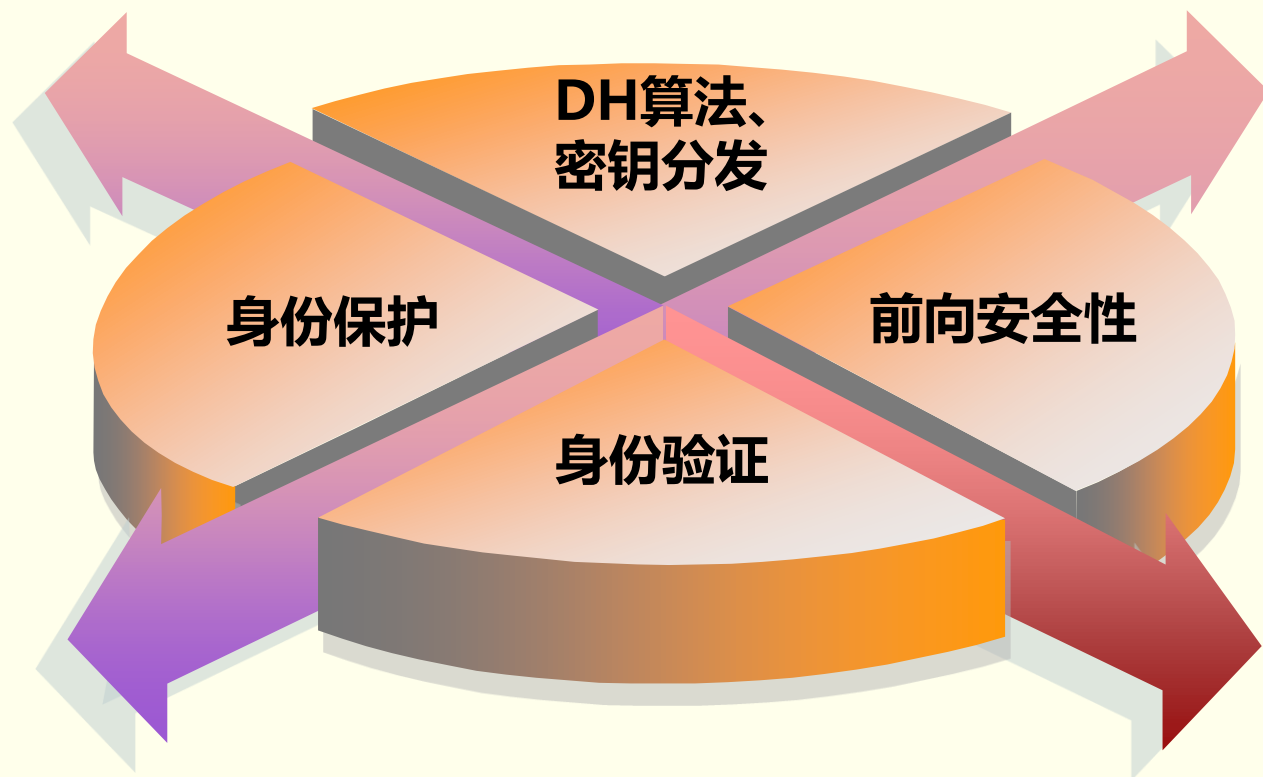


IKE概述



IKE的安全机制

- IKE具有一套自保护机制，可以在不安全的网络上安全地分发密钥、验证身份、建立IPSec安全联盟。



IKE在IPSec协议的作用

- 降低手工配置的复杂度
- 安全联盟定时更新
- 密钥定时更新
- 允许IPSec提供反重放服务
- 允许在端与端之间动态认证

安全联盟 (Security Association)

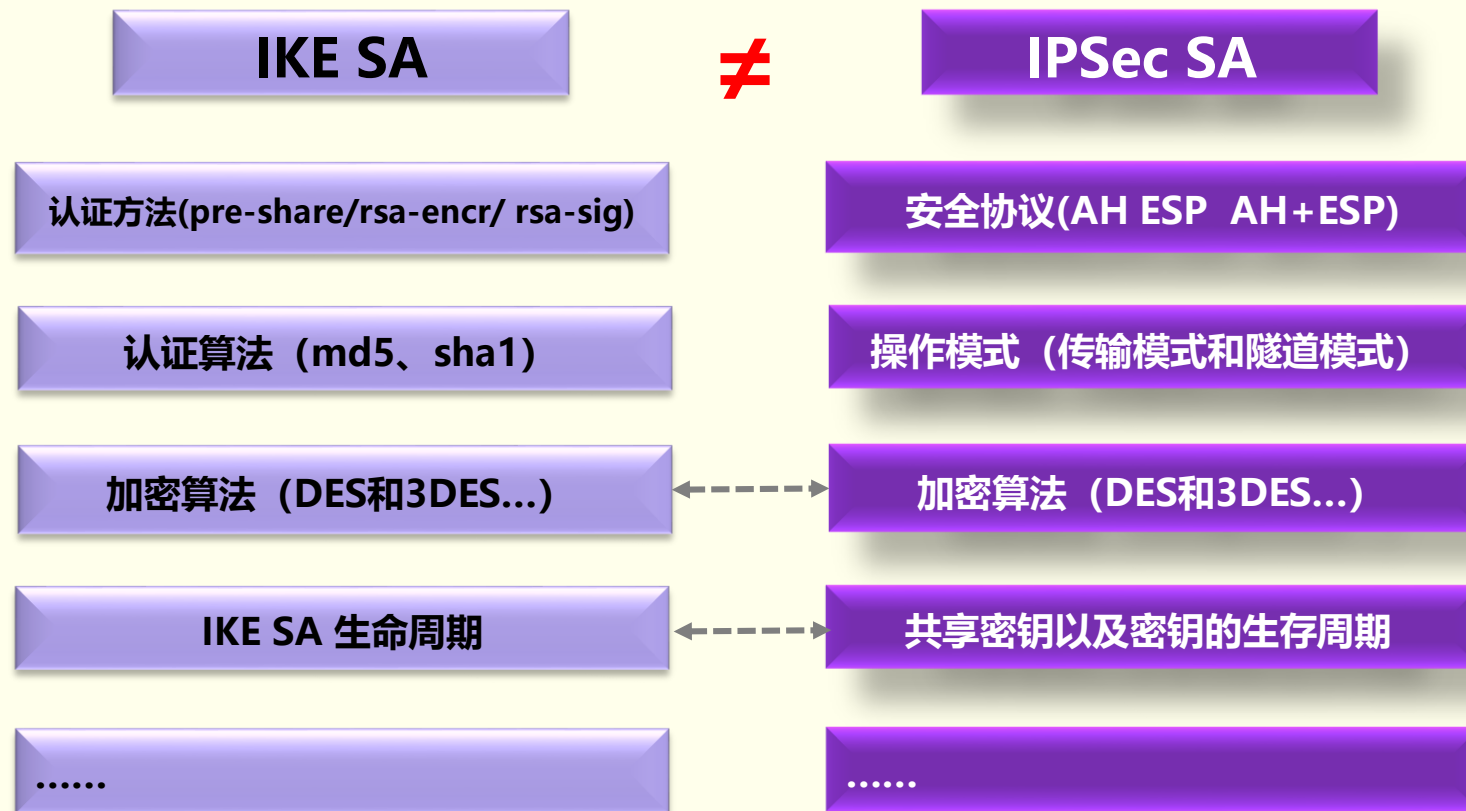
- 定义：
 - SA是通信对等体间对某些要素的约定 ,通信的双方符合SA约定的内容,就可以建立SA。
- SA由三元组来唯一标识 , 包括:

安全参数索引

目的IP地址

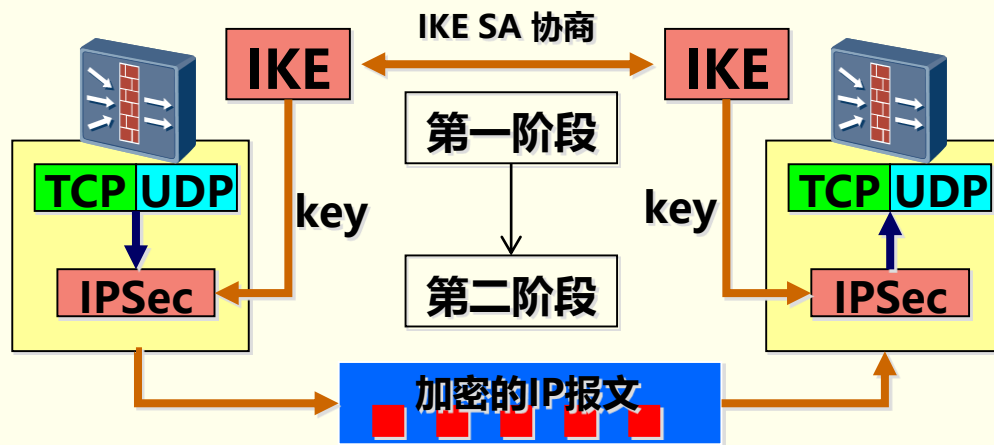
安全协议号

IKE SA与IPSec SA



IKE的交换阶段

- IKE使用了两个阶段为IPSec进行密钥协商并建立安全联盟：
 - 第一阶段，通信各方彼此间建立了一个已通过身份验证和安全保护的隧道，即IKE SA。协商模式包括主模式、野蛮模式。认证方式包括预共享密钥、数字签名方式、公钥加密。
 - 第二阶段，用在第一阶段建立的安全隧道为IPSec协商安全服务，建立IPSec SA。IPSec SA用于最终的IP数据安全传送。协商模式为快速模式。

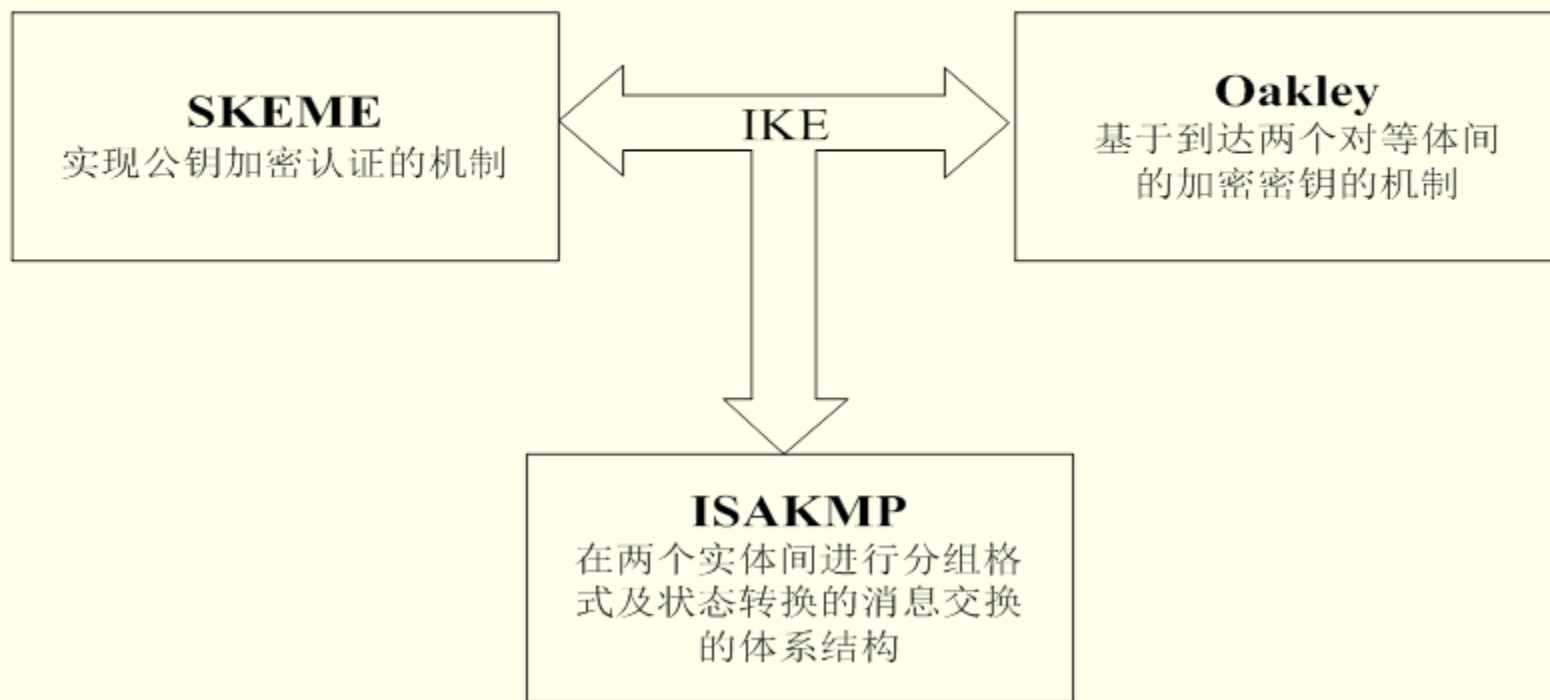


IKEv1 和IKEv2

- IKE协议分IKEv1和IKEv2两个版本。IKEv1使用两个阶段为IPSec进行密钥协商并建立IPSec SA。
 - 第一阶段，通信双方协商和建立IKE本身使用的安全通道，建立一个IKESA。
 - 第二阶段，利用这个已通过了认证和安全保护的安全通道，建立一对IPSec SA。
- IKEv2则简化了协商过程，在一次协商中可直接产生IPSec的密钥，生成IPSec SA。

IKEv1是一个复合协议

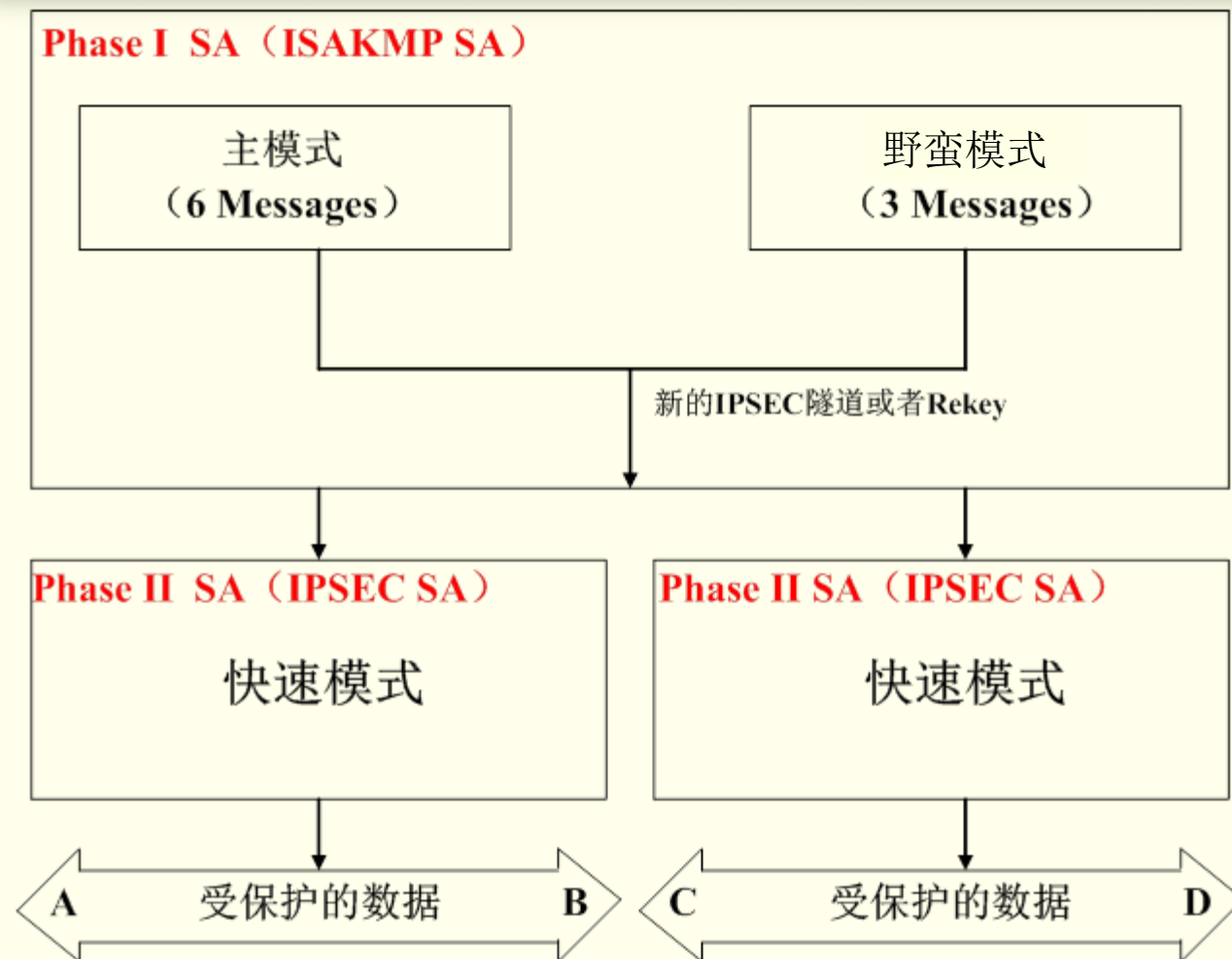
IKE的三个组件



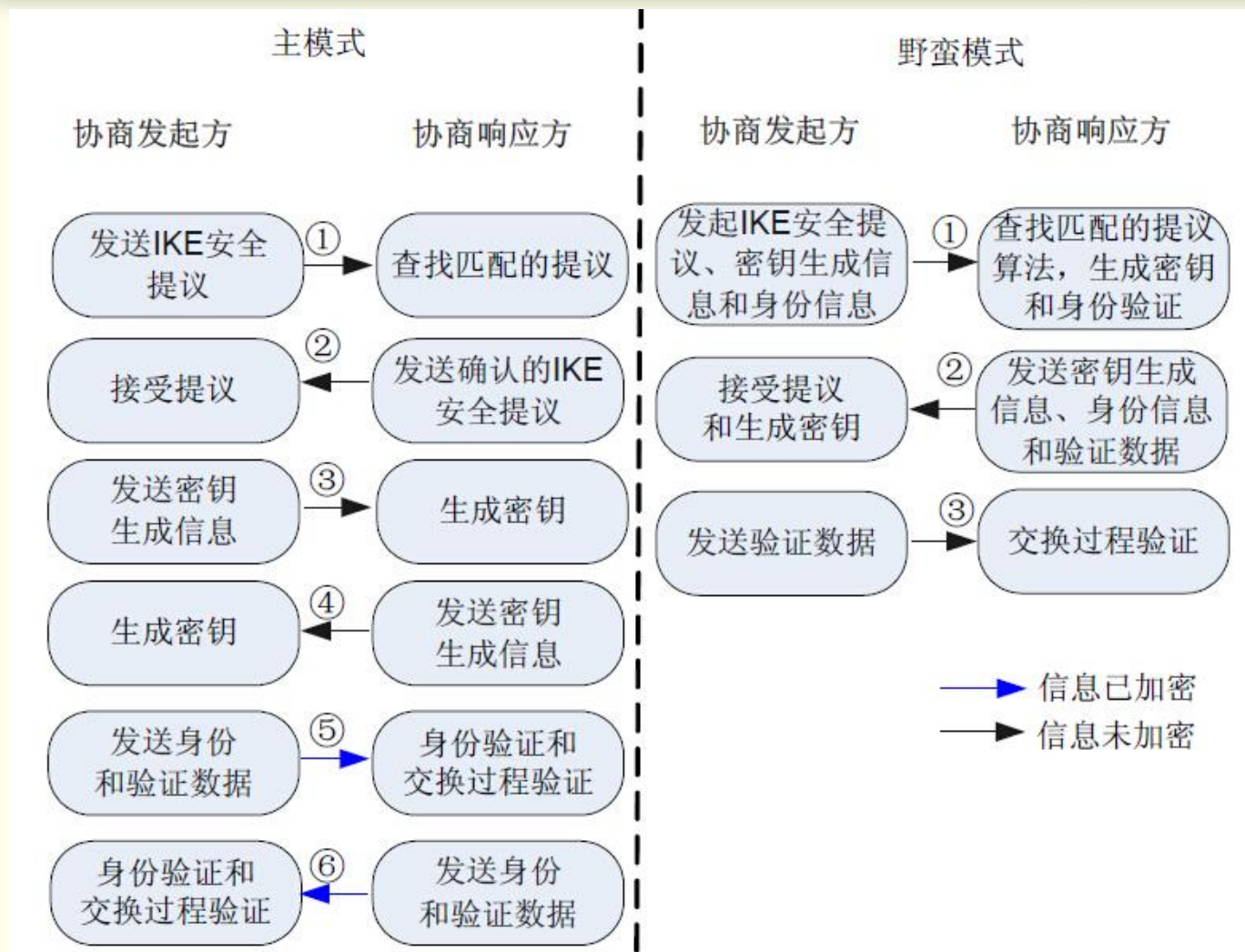
IKE主模式和野蛮模式区别

- 交换的消息：
 - 主模式为6个，野蛮模式为3个。
- 身份保护：
 - 主模式的最后两条消息有加密，可以提供身份保护功能；而野蛮模式消息集成度过高，因此无身份保护功能
- 对等体标识：
 - 主模式只能采用IP地址方式标识对等体；而野蛮模式可以采用IP地址方式或者Name方式标识对等体。

IKE的三个模式



主模式和野蛮模式交换过程图



野蛮模式适用场景

与主模式相比，野蛮模式减少了交换信息的数目，提高了协商的速度，但是没有对身份信息进行加密保护。虽然野蛮模式不提供身份保护，但它可以满足某些特定的网络环境需求。

- 当IPSec隧道中存在NAT设备时，需要启用NAT穿越功能，而NAT转换会改变对等体的IP地址，由于野蛮模式不依赖于IP地址标识身份，使得采用预共享密钥验证方法时，NAT穿越只能在野蛮模式中实现。
- 如果发起方的IP地址不固定或者无法预知道，而双方都希望采用预共享密钥验证方法来创建IKE SA，则只能采用野蛮模式。
- 如果发起方已知响应方的策略，或者对响应者的策略有全面的了解，采用野蛮模式能够更快地创建IKE SA。

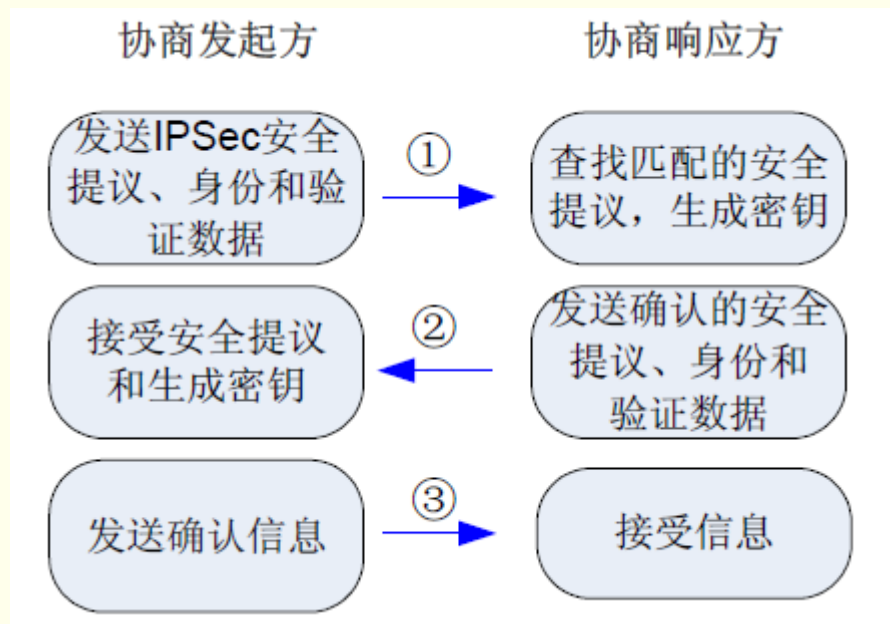
快速模式 (Quick Mode)

➤ 快速模式中,

- 双方需要协商生成IPSec SA各项参数 (包含可选参数PFS) ,
- 并为IPSec SA生成认证/加密密钥。

这在快速模式交换的前两条消息①和②中完成, 消息②中还包括认证响应方。消息③为确认信息, 通过确认发送方收到该阶段的消息②, 验证响应者是否可以通信。

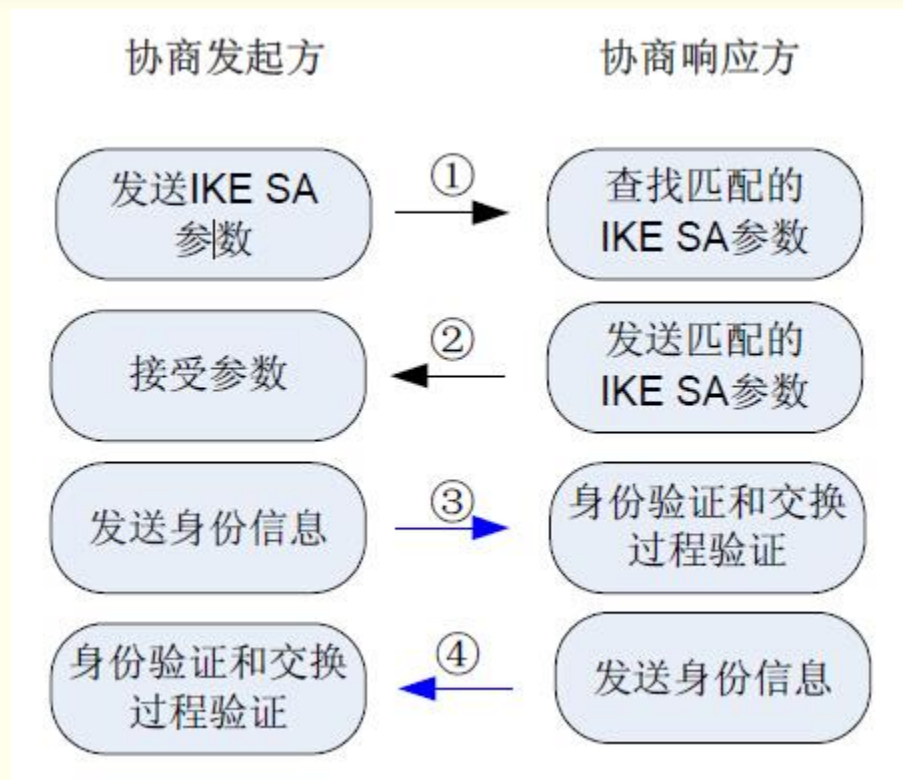
快速模式交换过程图



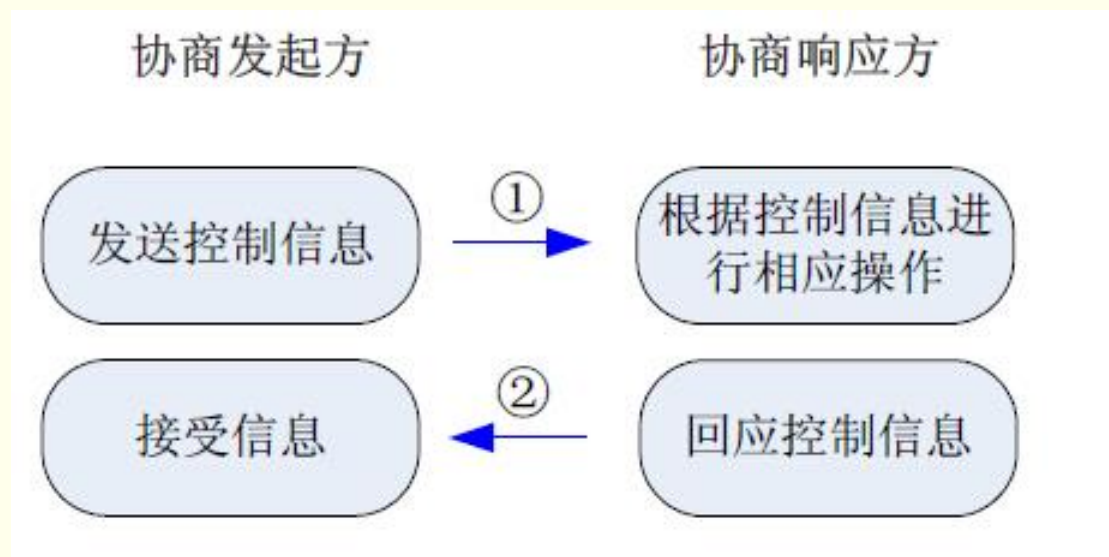
IKEv2密钥协商和交换

- IKEv2保留了IKEv1的大部分特性
 - IKEv1的一部分扩展特性（如NAT穿越）作为IKEv2协议的组成部分被引入到IKEv2框架中。
- IKEv2中所有消息都以“请求-响应”的形式成对出现
 - 与IKEv1不同，IKEv2中所有消息都以“请求-响应”的形式成对出现，响应方都要对发起方发送的消息进行确认，如果在规定的时间内没有收到确认报文，发起方需要对报文进行重传处理，提高了安全性。
- IKEv2还可以防御拒绝服务DoS（Denial of service）攻击
 - 在IKEv1中，当网络中的攻击方一直重放消息，响应方需要通过计算后，对其进行响应而消耗设备资源，造成对响应方的DoS攻击，而在IKEv2中，响应方收到请求后，并不急于计算，而是先向发起方发送一个Cookie类型的Notify载荷（即一个特定的数值），两者之后的通信必须保持Cookie与发起方之间的对应关系，有效防御了DoS攻击。

IKEv2初始交换过程图



IKEv2初始交换过程图



IKE 安全机制

身份认证

身份保护

DH (Diffie-Hellman) 密钥交换算法

完美的前向安全性PFS (Perfect Forward Secrecy)

身份认证

确认通信双方的身份（对等体的IP地址或名称），包括：

- 预共享密钥PSK (pre-shared key) 认证
- 数字证书RSA (rsa-signature) 认证
- 数字信封认证。

DH (Diffie-Hellman) 密钥交换算法

$$A = g^a \bmod p \quad (\text{DH}) \quad (\text{离散对数问题})$$

发起方公共值:

$$A = g^a \bmod p$$

接受方公共值:

$$B = g^b \bmod p$$

注意: DH组决定了g和p的大小

共享秘密

$$(A = g^a \bmod p)^b = (B = g^b \bmod p)^a = g^{ab}$$

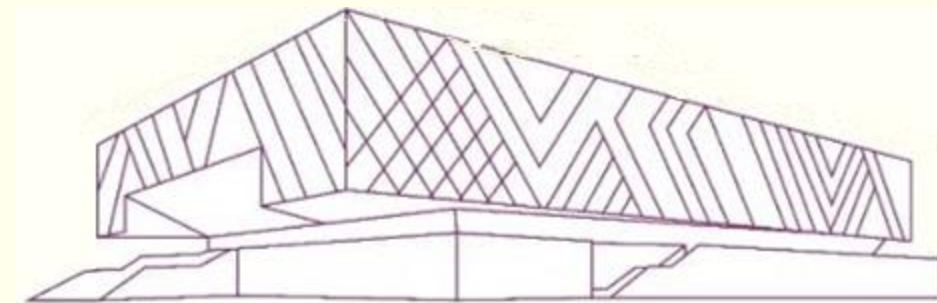
完美的前向安全性PFS

- 短暂的一次性密钥系统称为“完美向前保密”（Perfect Forward Secrecy, PFS）
- 如果加密系统中有一个秘密是所有对称密钥的衍生者（始祖），便不能认为那是一个“完美向前保密”的系统。在这种情况下，一旦破解了根密钥，便能拿到自它衍生的所有密钥，受那些密钥保护的全部数据都会曝光。
- 在IPSEC里,PFS是通过在IPSEC SA协商阶段重新进行一次D-H交换来实现的。



6

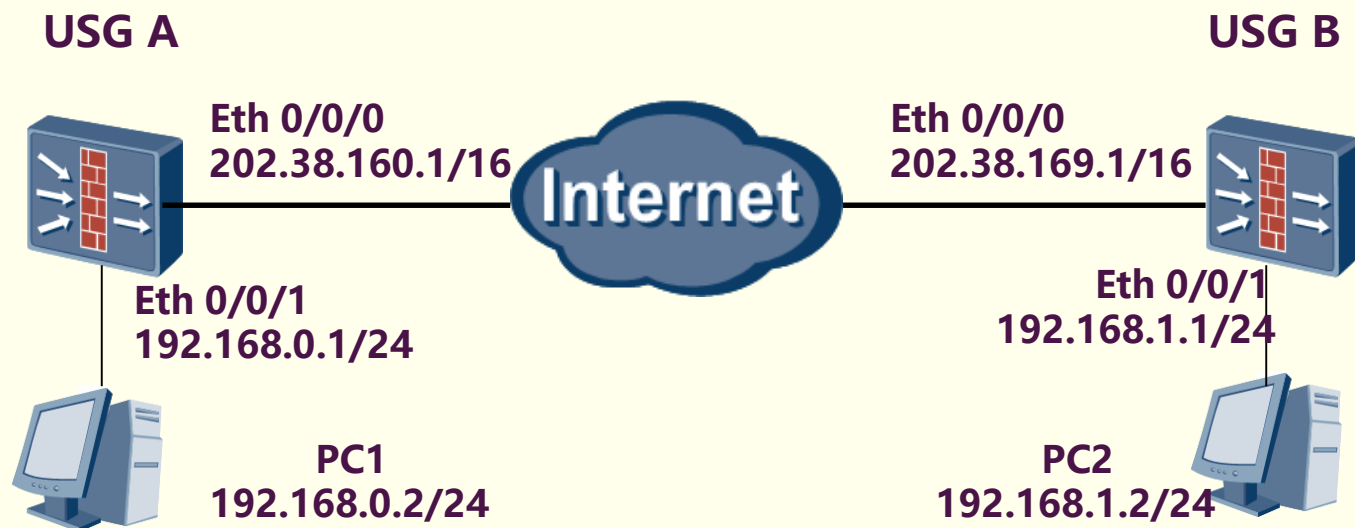
IPSec VPN应用场景分析



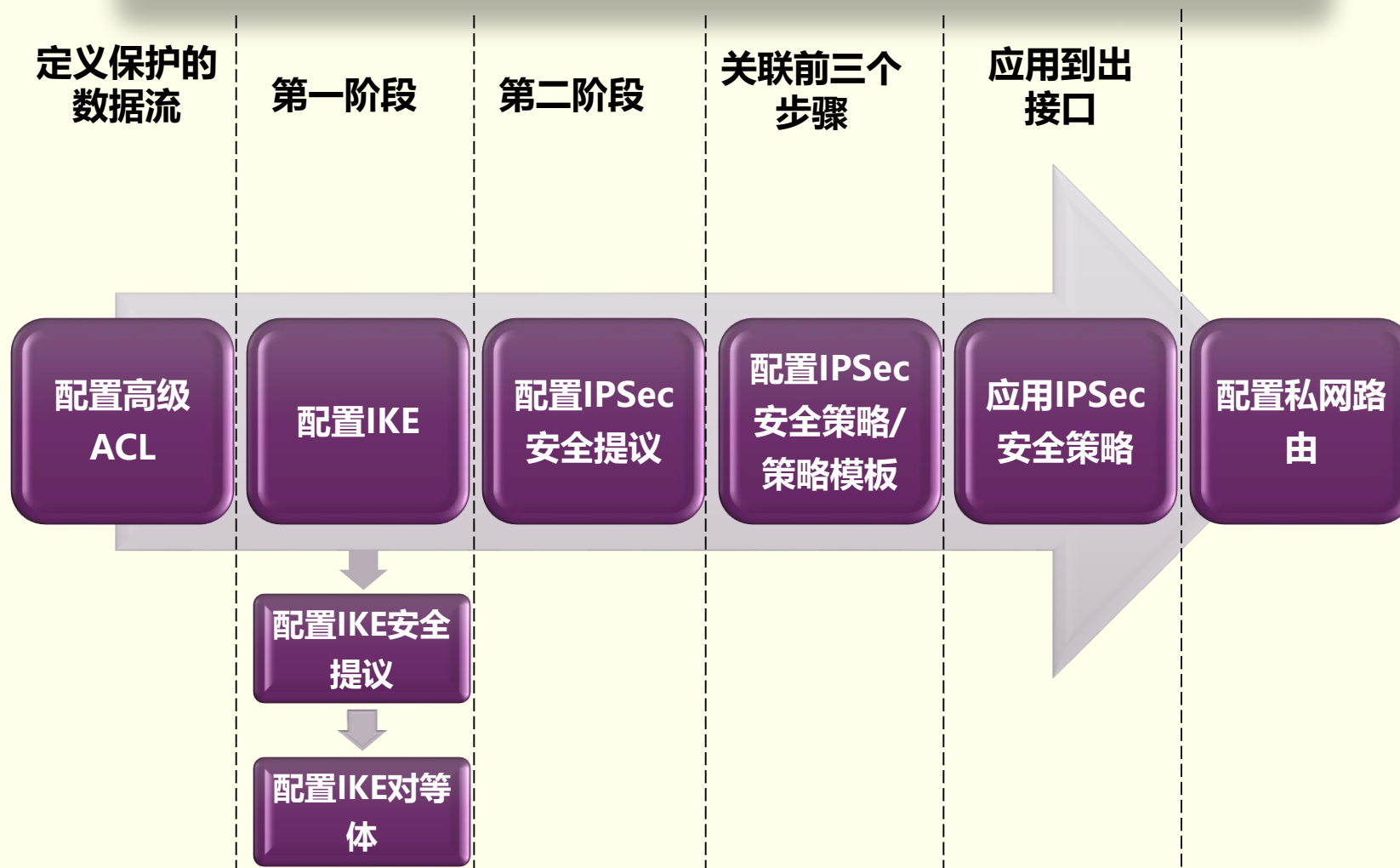
点对点IPSec应用场景

• 组网需求

- PC1与PC2之间进行安全通信，在FWA与FWB之间使用IKE自动协商建立安全通道。
- 在FWA和FWB上均配置序列号为10的IKE提议。
- 使用pre-shared key验证方法的提议配置验证字。
- FWA与FWB均为固定公网地址



IPSec VPN配置关键步骤



步骤一：定义需要保护的数据流

- 配置高级ACL，定义需要保护的数据流

```
[USG_A] acl 3000
```

```
[USG_A-acl-adv-3000] rule permit ip source 192.168.0.0 0.0.0.255  
destination 192.168.1.0 0.0.0.255
```

```
[USG_B] acl 3000
```

```
[USG_B-acl-adv-3000] rule permit ip source 192.168.1.0 0.0.0.255  
destination 192.168.0.0 0.0.0.255
```

步骤二：配置IKE

- 创建IKE安全提议

```
[USG_A] ike proposal 10
```

```
[USG_A-ike-proposal-10] authentication-method pre-share
```

```
[USG_A-ike-proposal-10] authentication-algorithm sha1
```

```
[USG_A-ike-proposal-10] integrity-algorithm hmac-sha1-96
```

- 配置IKE对等体

```
[USG_A] ike peer b
```

```
[USG_A-ike-peer-b] ike-proposal 10
```

```
[USG_A-ike-peer-b] remote-address 202.38.169.1
```

```
[USG_A-ike-peer-b] pre-shared-key abcde
```


步骤三：IPSec安全提议配置

- **创建IPSec安全提议**

- [USG_A] ipsec proposal tran1

- [USG_A-ipsec-proposal-tran1] encapsulation-mode tunnel

- [USG_A-ipsec-proposal-tran1] transform esp

- [USG_A-ipsec-proposal-tran1] esp authentication-algorithm md5

- [USG_A-ipsec-proposal-tran1] esp encryption-algorithm des

- **USG_B上的IPSec安全提议配置与USG_A相同**

步骤四：配置IPSec安全策略

- 创建安全策略

```
[USG_A] ipsec policy map1 10 isakmp
[USG_A-ipsec-policy-isakmp-map1-10] security acl 3000
[USG_A-ipsec-policy-isakmp-map1-10] proposal tran1
[USG_A-ipsec-policy-isakmp-map1-10] ike-peer b
[USG_A-ipsec-policy-manual-map1-10] quit
[USG_B] ipsec policy map1 10 isakmp
[USG_B-ipsec-policy-isakmp-map1-10] security acl 3000
[USG_B-ipsec-policy-isakmp-map1-10] proposal tran1
[USG_B-ipsec-policy-isakmp-map1-10] ike-peer a
[USG_B-ipsec-policy-isakmp-map1-10] quit
```

步骤五：应用IPSec安全策略

- 分别在USG_A和USG_B的外网出接口上引用各自的安全策略如下：
[USG_A] interface Ethernet 0/0/0
[USG_A- Ethernet0/0/2] ipsec policy map1
[USG_B] interface Ethernet 0/0/0
[USG_B- Ethernet0/0/2] ipsec policy map1

Web方式步骤一：配置IKE

配置IKE peer，
在防火墙B上的
配置应与防火墙
A对应。

配置IKE 对等体
远端地址。

VPN > IPSec > IKE协商 >

新建阶段1

阶段1	ike_a *
版本	☐ V1 ☐ V2 ☒ V1 and V2
协商模式	☒ 主模式 ☐ 野蛮模式
本地ID类型	名称 ▾
远端名称	ike_peer_b *
本地名称	ike_peer_a *
预共享密钥	 *
对端网关配置方式	固定地址 ▾
对端网关VPN实例	public ▾
对端网关IP	202 . 38 . 169 . 1 *
对端地址池范围	 - -
VPN实例	public ▾

— + 高级 —

应用 返回

Web方式步骤二：配置IKE高级选项

- 在阶段一“高级”选项中，指定加密及认证算法

高级

加密算法

DES-CBC

认证算法

SHA1

DH组

DH-Group1

完整性算法

HMAC-SHA1

SA超时时间

86400

* <60-604800>秒

DPD工作模式

---- NONE ----

NAT穿越

☒ 启动

对端认证IP地址

Web方式步骤三：IPSec安全提议配置

- 在Web界面下，IPSec安全提议的配置在IKE第二阶段中实现。

在“新建阶段2”
界面中，配置
阶段2参数

实质上，IKE阶
段二的内容既
为IPSec安全提
议配置中所需
要配置的内容。

VPN > IPSec > IKE协商

新建阶段2

阶段2 * - * <1-10000>

阶段1

☒ 高级

封装模式	隧道模式
安全协议	ESP
ESP加密算法	DES
ESP认证算法	MD5
PFS	---- NONE ----
SA超时	基于时间 3600 <480-604800>秒
	基于流量 1843200 <8000-4194303>千字节
反向路由注入	☐ 启用 ?

应用 返回

Web方式步骤四：定义保护的数据流

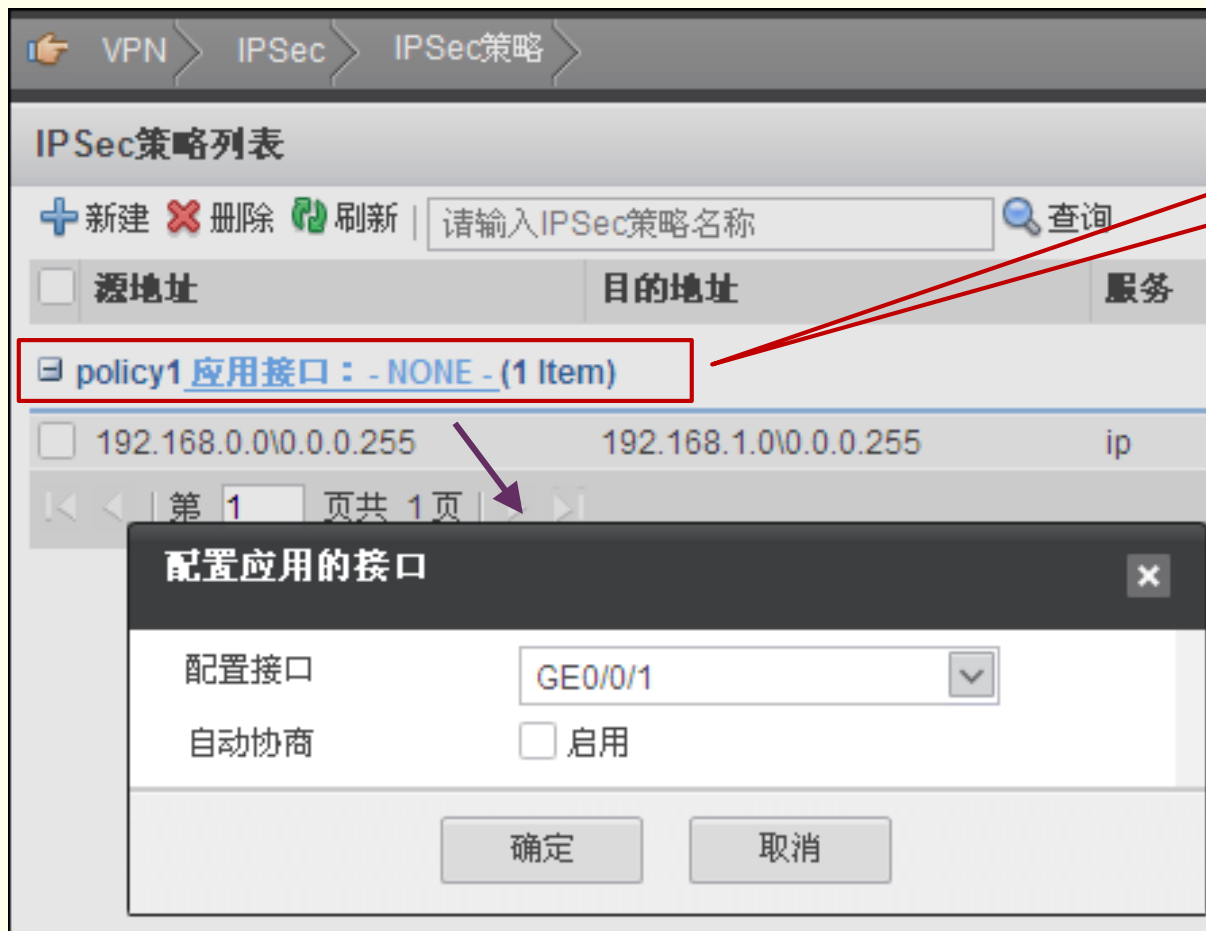
在IPSec安全策略中定义保护的数据流。

The screenshot shows the '新建IPSec策略' (New IPSec Policy) configuration window. The breadcrumb navigation at the top is 'VPN > IPSec > IPSec策略'. The window contains the following fields:

- IPSec策略: policy1-1
- 数据流配置方式: ☒ 指定数据流, ☐ L2TP over IPSec
- 源地址: 192.168.0.0/255.255.255.0
- 目的地址: 192.168.1.0/255.255.255.0
- 服务: ip
- 动作: permit

Buttons at the bottom right are '应用' (Apply) and '返回' (Return).

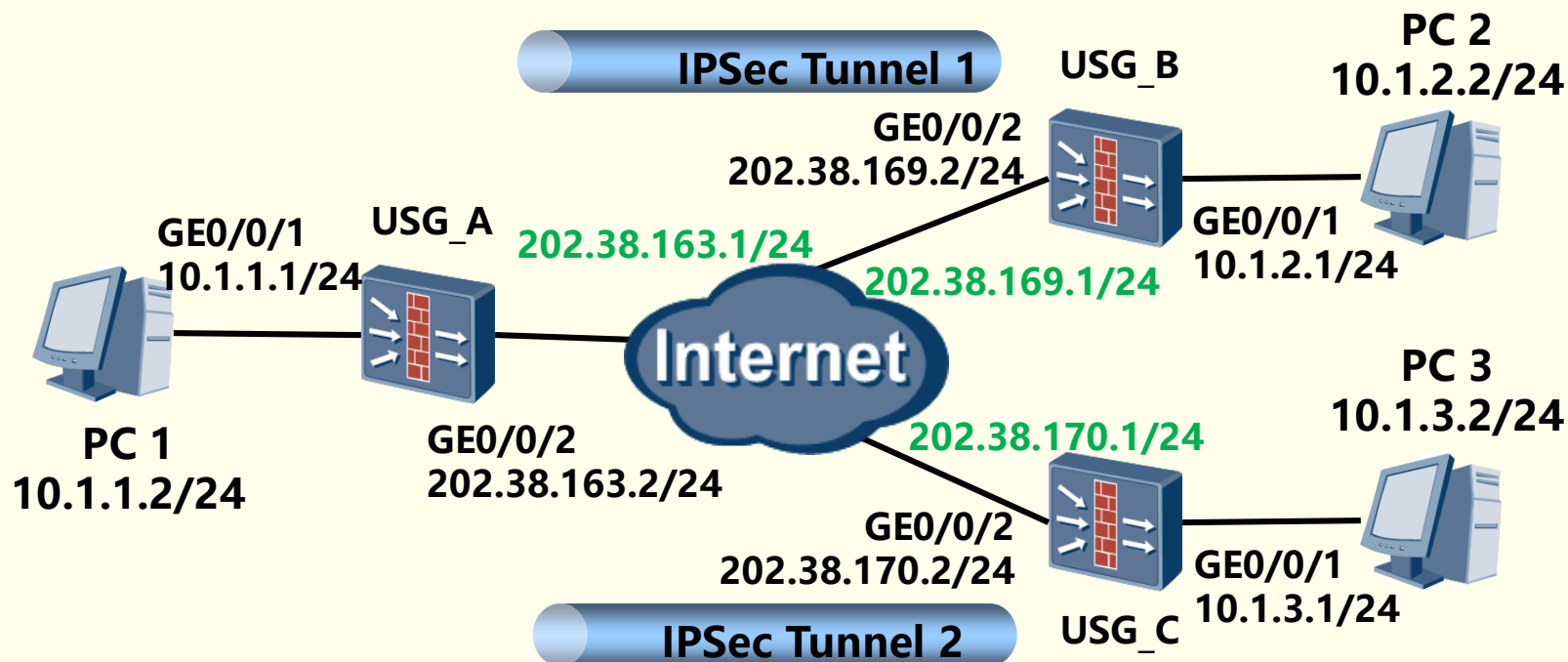
Web方式步骤五：应用IPSec安全策略



应用IPSec策略到接口上。

点对多点IPSec应用场景

- 一个总部到多个分支机构的组网，分支节点建立到总部的IPSec隧道。



IPSec VPN配置向导(Web)

IPSec VPN隧道配置向导

1 选择应用场景

2 配置网络

3 定义受保护数据流

4 配置加密与认证

5 配置信息汇总

选择应用场景 (1/5)

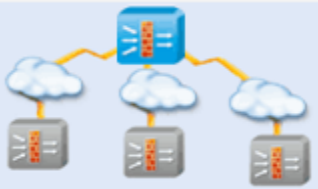
选择启用IPSec配置的场景。

☒ 网关到网关



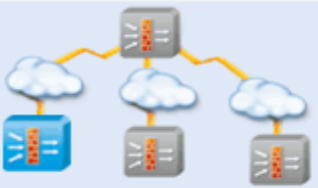
该场景用来配置网关到网关的连接中，可配置任何一端的网关

☐ 中心网关



该场景用来配置星形结构中的中心端网关，采用策略模板的方式

☐ 分支网关



该场景用来配置星形结构中的分支端网关

☐ L2TP over IPSec



该场景用来配置L2TP over IPSec的场景中，配置可通过客户端远程接入的网关

<上一步

下一步>

取消

IPSec结果验证与维护命令

- 查看到两条双向IPSec SA

```
<FWA>display ipsec sa brief
```

current ipsec sa number: 2

Src Address	Dst Address	SPI	VPN	Protocol	Algorithm
202.38.160.1	202.38.169.1	957073432	0	ESP	E:DES;A:HMAC-MD5-96;
202.38.169.1	202.38.160.1	2838744079	0	ESP	E:DES;A:HMAC-MD5-96;

IPSec结果验证与维护命令

- 查看到IKE peer和IKE sa的信息

```
<sysname> display ike sa
current ike sa number: 4
-----
conn-id      peer                flag    phase    vpn
-----
101          202.38.169.1 :2048  RD      v2:2     public
100          202.38.169.1 :2048  RD      v2:1     public
17           1.1.1.2             RD|ST   v2:2     v12
7            1.1.1.2             RD|ST   v2:1     v12
flag meaning
RD--READY ST--STAYALIVE RL--REPLACED FD--FADING
TO--TIMEOUT TD--DELETING NEG--NEGOTIATING D--DPD
```

IPSec VPN配置注意事项

防火墙上必须有到达对方私网网段的正确路由

**主动触发IPSec VPN的防火墙ACL中必须定义Source
字段,推荐双方的ACL的互为镜像**

**配置Local和Untrust域间缺省包过滤规则的目的为允许
IPSec隧道两端设备通信,使其能够协商SA**



结 束

